

HUMAIN Create Studio

PREPARED BY  AAVYA

Payload CMS v3 — Security Posture

Headless CMS Security Overview

Subject	Payload CMS v3 security posture for HUMAIN Create Studio
Payload version	3.85.0 (Payload v3.x)
Prepared by	Aavya
Prepared for	HUMAIN / IT Security
Classification	Confidential
Date	June 2026

1. Summary

Payload CMS v3 is a secure, production-grade foundation, and this platform already applies the key controls. Payload is an actively maintained, TypeScript-native headless CMS (Figma-backed since 2025) running on the Next.js App Router. Security is a **shared responsibility**: Payload provides strong primitives, and this deployment configures and hardens them appropriately. The pinned version is **3.85.0** (a current v3 patch).

Bottom line: suitable for production — keep it patched, harden the configuration, and monitor security advisories.

2. Built-in Security Controls (Payload v3)

Control	Detail
Authentication	bcrypt-hashed passwords · JWT in httpOnly cookies · API keys · email verification · password reset · account lockout (<code>maxLoginAttempts</code> / <code>lockTime</code>)
Authorization	Collection- and field-level access-control functions → real RBAC + ABAC
Injection defence	Parameterised queries via Drizzle ORM (Postgres) — strong against SQL injection
Web security	CORS + CSRF controls, configurable allowed origins; inherits the Next.js security model and patch cadence
Data integrity	Versioned drafts, editorial workflow state, and audit hooks
Maintenance	Actively maintained, well-resourced project; pinned, recent 3.85.0

3. This Platform's Applied Controls

Area	Configuration in HUMAIN Create Studio
Transport	HTTPS/TLS everywhere · <code>COOKIE_SECURE=true</code> · secure session cookies
Access control	RBAC (7 roles) + ABAC (site-scope, department, locale) enforced at collection and field level; roles/scope admin-editable only (no self-escalation); <code>siteAdmin</code> confined to its sites; behaviourally verified by a per-role allow/deny test suite
Secrets	<code>PAYLOAD_SECRET</code> and provider keys held in environment (<code>.env.production</code>), not committed to source
Governance	Editorial gating (draft → review → publish) · immutable audit log of content and agent actions
Agentic safety	Agents propose drafts ; a human approves before anything is published
Sovereignty	Hosted in-Kingdom ; secrets isolated from content and code

4. Hardening Checklist

- **Keep Payload patched** and subscribe to its security advisories (GitHub Security Advisories / release notes).
- Use a strong, rotated `PAYLOAD_SECRET` ; restrict `/admin` exposure.
- Enable **dependency / SCA scanning** (Dependabot / Snyk / `npm audit`) in CI.
- Replace the first-boot **dev schema-push with generated Payload migrations**.
- Apply **edge rate-limiting / WAF**; use least-privilege database and registry credentials.
- Enforce MFA for administrative/maintainer access.

5. Shared Responsibility

Payload supplies the security tools; secure operation depends on configuration, deployment and upkeep. Most real-world risk lies in weak secrets, over-permissive access rules, leaked environment variables, or unpatched dependencies — all addressed by the controls and checklist above. No framework can be declared free of vulnerabilities; the correct posture is to **stay current and monitor advisories**.

Prepared by Aavya for HUMAIN / IT Security — Confidential. Payload CMS v3 (3.85.0) security posture for HUMAIN Create Studio.